Clase 259 — Defensa contra la ingeniería social

> Parte: **12 — OSINT e ingeniería social** · Fuente: NIST SP 800-50 · *Social Engineering* (C. Hadnagy) · ENISA ⏱️ Duración estimada: **110 min** · Nivel: **Intermedio**

🎯 Objetivo

Diseñar un programa de defensa contra la ingeniería social que combine controles técnicos, procesos y cultura. El alumno terminará capaz de proponer medidas anti-phishing (SPF/DKIM/DMARC, MFA resistente, filtros), procedimientos de verificación de identidad y un programa de concienciación medible, cerrando el ciclo iniciado con el ataque autorizado.

> 🔗 **Continuación en la Parte 21:** la defensa organizacional continúa con la contrainteligencia empresarial (378) y la protección de ejecutivos (379).

📚 Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Implementar** autenticación de correo (SPF, DKIM, DMARC) para reducir la suplantación.
2. **Seleccionar** controles técnicos anti-phishing y MFA resistente a phishing.
3. **Diseñar** procedimientos de verificación de identidad para helpdesk y pagos.
4. **Construir** un programa de concienciación con métricas de resiliencia.
5. **Definir** un flujo de reporte y respuesta ante incidentes de ingeniería social.
6. **Descomponer** un lanzamiento viral en identidad, origen, secreto, autorización y efecto para aplicar controles específicos.

🗺️ Temas

#	Tema	Por qué importa
1	Autenticación de correo	Frena la suplantación de dominio
2	MFA resistente a phishing	Neutraliza el robo de credenciales
3	Filtros y sandboxing	Bloquea el gancho antes del clic
4	Verificación de identidad	Corta pretexting y vishing
5	Concienciación medible	Cambia el comportamiento
6	Botón de reporte	Convierte usuarios en sensores
7	Respuesta a incidentes SE	Contiene el daño rápido
8	Airdrops, wallets y firmas	La interfaz visible puede ocultar otra autorización
9	Recuperación por tipo de exposición	Un permiso, una seed y una sesión requieren respuestas distintas

🧠 Explicación en profundidad

Defender significa que una sola decisión humana no produzca un desastre

La concienciación ayuda, pero ninguna persona mantiene atención perfecta. La arquitectura debe asumir mensajes convincentes, cuentas comprometidas y momentos de presión. Se combinan controles preventivos, resistentes, detectivos y de recuperación: autenticación ligada al dominio, verificación de transacciones, filtrado, privilegios mínimos, reporte sencillo, revocación de sesiones y respuesta coordinada.



Autenticación y autorización de negocio no son lo mismo. Passkeys/WebAuthn bien configuradas resisten el phishing mediante vinculación al verificador, como describe NIST SP 800-63B-4; SMS y OTP introducidos manualmente no ofrecen esa propiedad frente a un intermediario. Aun con autenticación resistente, un usuario puede autorizar voluntariamente una transferencia falsa. Los procesos de alto impacto necesitan confirmación de datos, doble control y límites.

Reportar debe ser más fácil que ignorar

Un botón de reporte conserva encabezados y mensaje original, informa al usuario y alimenta automatización. SOC deduplica campañas, busca destinatarios, bloquea indicadores y evalúa cuentas. El

canal debe aceptar dudas: penalizar falsos reportes reduce la detección temprana. Las métricas incluyen tiempo desde recepción hasta primer reporte y desde reporte hasta contención, además de cobertura de autenticación resistente y cumplimiento de callback.

Responder por escenario

Si alguien hizo clic, se determina qué se ejecutó y qué datos se entregaron. Si ingresó una contraseña, se restablece, revocan sesiones y tokens, se revisan reglas de correo y actividad posterior; cambiar la contraseña sin revocar sesiones puede ser insuficiente. Si aprobó una transacción, se activa fraude y recuperación. Si solo recibió el mensaje, todavía aporta inteligencia para proteger a otros.

Del video viral al drainer: romper la cadena por autoridad

Un lanzamiento viral combina palancas conocidas —autoridad aparente, prueba social, escasez, urgencia y recompensa— con una interfaz técnica poco familiar. El usuario ve un video, busca el token, llega a un dominio parecido, encuentra cuentas que se refuerzan entre sí y recibe un airdrop. La defensa no consiste en memorizar una lista de marcas confiables: consiste en preguntar **qué identidad, origen, secreto o autoridad cambia en cada paso**.

La cadena se lee así: **video viral → búsqueda → sitio no corroborado o cuenta falsa/tomada → airdrop urgente → conexión → petición decodificada**. Desde allí se bifurca: una sesión sin cambio de estado, una seed que compromete claves, o un permiso/transacción que crea capacidad de gasto y puede terminar en movimiento de activos.

El diagrama se lee como una serie de controles independientes. El video se valida por procedencia; la cuenta, por historia y sesión; el dominio, por un canal conocido; el activo, por red e identificador de contrato/mint; la petición, por sus efectos decodificados. **Conectar una wallet no equivale por sí solo a mover activos**. Puede revelar una dirección pública y permitir solicitudes posteriores. El riesgo material aparece cuando se firma una operación, se concede un permiso persistente, se firma un mensaje con uso autorizador o se entrega una frase semilla/clave. La semántica exacta depende de la red: contratos y programas no comparten un formato universal.

Un **wallet drainer** es el flujo que adquiere y usa capacidad para mover activos; no es una categoría mágica de botón. Puede apoyarse en approvals excesivos, firmas engañosas o secretos robados. Una solicitud de frase semilla debe detener el flujo: soporte legítimo no necesita el secreto raíz. Un ataque de portapapeles es otra ruta, ligada a malware de endpoint, que sustituye una dirección copiada. Y un **rug pull** es distinto de todos ellos: puede ocurrir con dominio y activo auténticos cuando promotores retiran liquidez, venden o abandonan en contradicción con lo prometido. Confundirlos lleva a respuestas inútiles.

Recuperar según lo que quedó expuesto

La respuesta empieza deteniendo nuevas decisiones y preservando URL, dominio, cuentas, publicación, hora, petición decodificada, TXID y telemetría. Después se ramifica:

Condición observada	Acción inicial	Por qué
solo visita o conexión, sin firma ni secreto	cerrar, desconectar sesión si aplica, vigilar y reportar	no afirmar pérdida que no se observa
approval/permiso peligroso sin gasto	revocar mediante canal/herramienta verificada y monitorear	el permiso puede seguir activo tras cerrar la web
transferencia confirmada	preservar transacción, proteger lo restante y contactar proveedores verificados	cambiar contraseña no revierte estado de la red
frase semilla o clave expuesta	tratar la wallet como comprometida y migrar desde un dispositivo limpio	el secreto no se «revoca» como una sesión
cuenta social tomada	revocar sesiones, recuperar identidad, preservar posts y avisar por otro canal	borrar el post sin cerrar sesiones deja la causa activa
sustitución de portapapeles	aislar y adquirir endpoint antes de volver a operar	la wallet puede estar sana mientras el host altera destinos

Revocar, migrar o contactar un proveedor puede tener costes y riesgos; se ejecuta con el runbook de la wallet/red y autoridad apropiada. Nunca se pega una seed en una web de «recuperación» ni se paga a un supuesto recuperador que contacta de forma no solicitada.

Caso razonado: MFA que no detuvo el ataque

Una víctima entrega contraseña y OTP a un proxy en tiempo real. El atacante obtiene sesión. La organización no concluye que «MFA no sirve»; identifica que ese autenticador no era resistente al phishing, revoca sesiones y migra accesos críticos a WebAuthn, manteniendo detección y recuperación. También revisa por qué la página falsa llegó y cómo se reportó.

📕 Glosario operativo

Término	Definición útil
Phishing resistance	Propiedad protocolaria que evita entregar una salida válida a un verificador impostor.
Session revocation	Invalidación de sesiones y tokens ya emitidos.
Callback	Verificación por un canal conocido e independiente.
Doble control	Participación de dos autorizadores en una acción crítica.
Triage	Clasificación inicial que determina alcance, urgencia y respuesta.
Approval / permiso	Autoridad concedida a un tercero para actuar sobre un activo según el protocolo.
Wallet drainer	Cadena que obtiene y usa autoridad para mover activos; requiere identificar el mecanismo concreto.
Frase semilla	Secreto raíz del que pueden derivarse claves; exponerla exige tratar la wallet como comprometida.
Rug pull	Riesgo de promotor/liquidez o abandono; no es sinónimo de phishing ni de drainer.

✅ Criterio de dominio

El alumno domina la defensa cuando puede mapear una solicitud a controles técnicos y de proceso, diferenciar tipos de MFA, diseñar reporte y respuesta, y medir reducción de riesgo sin responsabilizar únicamente al usuario.

📖 Definiciones y características

- **SPF/DKIM/DMARC:** mecanismos DNS que autentican el correo. Característica: con DMARC en `p=reject` el dominio es difícil de suplantar.
- **MFA resistente a phishing:** factores no interceptables (FIDO2/passkeys). Característica: derrotan páginas falsas y proxies AiTM.
- **Sandboxing de adjuntos/URL:** detonación en entorno aislado. Característica: detecta payloads antes del usuario.
- **Verificación fuera de banda:** confirmar por un canal distinto al de la petición. Característica: frustra pretextos urgentes.
- **Tasa de reporte:** proporción de usuarios que reportan un correo sospechoso. Característica: indicador clave de cultura.
- **Playbook de respuesta:** guía de acciones ante un incidente. Característica: reduce el tiempo de contención.
- **Verificación del activo:** comparación de red e identificador canónico, no solo nombre o símbolo. Característica: detecta tokens imitadores.
- **Decodificación de transacción:** traducción de operaciones, cuentas, destinos y permisos a efectos comprensibles. Característica: permite comparar intención visible con autoridad real.

🧰 Herramientas y preparación

- **Correo:** registros DNS SPF/DKIM/DMARC; analizadores como MXToolbox o `dig`.
- **MFA:** llaves FIDO2/passkeys; políticas de acceso condicional.
- **Filtrado:** pasarela de correo con sandboxing y reescritura de URL.
- **Reporte:** botón "Reportar phishing" integrado en el cliente de correo.
- **Formación:** plataforma de awareness con simulacros (enlaza con GoPhish, Clase 258).

🧪 Laboratorio guiado (ejercicio aplicado)

1. Publica y valida SPF de un dominio de laboratorio: `dig TXT tudominio.com` y revisa el registro.
2. Configura DMARC en modo monitor: crea `_dmarc` con `v=DMARC1; p=none; rua=mailto:...` y observa los reportes.
3. Endurece a `p=quarantine` y luego `p=reject` tras validar que el correo legítimo pasa.
4. Diseña un procedimiento de **verificación fuera de banda** para el helpdesk (reseteos de contraseña).
5. Redacta un procedimiento antifraude para pagos: doble aprobación y verificación por canal conocido.
6. Define el flujo del **botón de reporte**: destino, triage y retroalimentación al usuario.
7. Construye un plan de concienciación trimestral con simulacros y métricas.
8. Escribe un mini-playbook de respuesta ante una campaña de phishing detectada.
9. Resuelve el laboratorio OrbitPup y asigna a cada evento un control preventivo, detectivo o correctivo. No conectes una wallet real.

✍️ Ejercicios

1. Explica cómo DMARC `p=reject` frustra un ataque de suplantación de dominio.
2. Compara MFA por SMS vs. FIDO2 frente a un ataque AiTM.
3. Diseña 5 preguntas de verificación de identidad robustas para el helpdesk.
4. Propón métricas de un programa de awareness más allá de la tasa de clic.
5. Redacta el mensaje de retroalimentación positiva a quien reporta un phishing.
6. Elabora un playbook de contención para credenciales comprometidas.
7. Compara la respuesta a cuatro hechos: approval firmado, seed expuesta, clipboard sustituido y retiro de liquidez. Explica por qué una única acción no sirve para los cuatro.

📝 Reto verificable

Entrega un **plan de defensa contra ingeniería social** que cubra: autenticación de correo, MFA resistente, verificación de identidad, programa de concienciación con métricas y playbook de respuesta. **Criterio de aceptación:** el plan incluye configuración DMARC verificable, al menos un control por cada vector (phishing, vishing, pretexting y lanzamiento viral) y métricas que midan resiliencia, no solo víctimas. Para el caso viral debe separar conexión, firma/permiso, secreto y efecto observado.

⚠️ Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
DMARC rompe correo legítimo	Se pasó a `reject` sin monitorizar. Empieza en `p=none`, analiza y sube gradualmente.
MFA por SMS eludido	Vulnerable a AiTM/SIM swap. Migra a FIDO2/passkeys.
Usuarios no reportan	No hay botón o hay miedo a represalias. Facilita el reporte y refuerza positivamente.
Awareness sin efecto	Formación anual aburrida. Usa simulacros frecuentes y feedback inmediato.
Helpdesk resetea sin validar	Falta verificación fuera de banda. Implanta preguntas y canal alternativo.
«El candado prueba que el airdrop es oficial»	TLS protege el canal al dominio visitado; corrobora dominio, cuenta y activo por vías independientes.
«Conectar drenó la wallet»	Busca la firma, permiso, transacción o secreto que creó capacidad; la conexión puede no cambiar estado.
Revocar approval tras exponer la seed	El permiso se revoca, la seed no; migra a una wallet nueva con un procedimiento seguro.
Llamar rug pull a una caída de precio	Exige evidencia de control, retiro/venta/abandono y relación con lo prometido.

❓ Preguntas frecuentes

❓ **¿DMARC elimina el phishing?** Reduce la suplantación de **tu** dominio, no los correos de dominios parecidos (typosquatting). Es una capa, no la solución completa.

❓ **¿Basta con formar a la gente?** No. La concienciación es una capa junto a controles técnicos. Culpar solo al usuario es un antipatrón; diseña sistemas que fallen de forma segura.

❓ **¿Qué MFA resiste el phishing?** FIDO2/WebAuthn y passkeys, porque la autenticación está ligada al origen y no puede reproducirse en una página falsa.

❓ **¿Una simulación de transacción garantiza seguridad?** No. Ayuda a anticipar efectos de una ejecución bajo un estado concreto, pero puede tener cobertura o presentación incompleta y no prueba identidad del proyecto, seguridad futura ni ausencia de permisos persistentes. Se combina con decodificación, límites y verificación independiente.

🔗 Referencias

- NIST SP 800-50 — Awareness and Training. https://csrc.nist.gov/pubs/sp/800/50/final
- DMARC.org. https://dmarc.org/
- FIDO Alliance — Passkeys. https://fidoalliance.org/passkeys/
- CISA — Avoiding Social Engineering and Phishing. https://www.cisa.gov/
- ENISA — Cybersecurity awareness. https://www.enisa.europa.eu/

- NIST SP 800-63B-4 — Authenticator and Verifier Requirements. https://pages.nist.gov/800-63-4/sp800-63b/authenticators/
- MetaMask — *What is a token approval?*: permisos de gasto, approvals maliciosos y revocación en ese ecosistema. https://support.metamask.io/stay-safe/safety-in-web3/what-is-a-token-approval/
- MetaMask — canales oficiales de soporte: respalda que una solicitud de frase de recuperación es una señal de estafa. https://support.metamask.io/stay-safe/safety-in-web3/what-are-metamasks-official-support-channels/
- SEC — alerta sobre estafas con criptoactivos: suplantación, cuentas tomadas, promoción social y memecoins; no sustituye el análisis técnico de un caso. https://www.investor.gov/introduction-investing/general-resources/news-alerts/alerts-bulletins/investor-alerts/crypto-scams

📥 Material descargable

- 📄 Guía en PDF — versión imprimible de esta clase.
- 🎞️ Presentación (PPTX) — deck para proyectar en clase.

⬅️ Clase anterior

Clase 258 — Campañas de phishing con GoPhish

➡️ Siguiente clase

Clase 260 — OPSEC personal y anonimato